PROTOCOLO DE RESPUESTA A INCIDENTES

1- Marco conceptual

Un protocolo de seguridad informática es un conjunto de reglas y procedimientos diseñados para proteger la integridad, la confidencialidad y la disponibilidad de la información, estableciendo las bases para la autenticación de usuarios, el cifrado de datos y la comunicación segura entre sistemas (Bambu Mobile, 2024). Sobre esa misma línea, se reconocen tres componentes centrales que sostienen cualquier protocolo de seguridad, la autenticación de los usuarios, el cifrado de datos y la organización de los datos (Benegas, s.f.)

El presente protocolo aplica estos tres componentes de la siguiente manera dentro del SGRSI:

Elemento	Aplicación en el SGRSI
Autenticación de usuarios	Login con control de sesiones y autenticación basada en roles (RBAC): Solicitante, Técnico/Soporte y Administrador/Coordinador
Cifrado de datos	Encriptación de contraseñas en la base de datos y uso de HTTPS/TLS para el tráfico entre el cliente y el servidor de aplicación
Organización de los datos	Base de datos normalizada a 3FN y servidor de respaldo como sistema de contingencia ante pérdidas de información

Asi mismo, el protocolo SSH (Secure Shell) constituye la base técnica de la administración remota del servidor, protege la comunicación entre el cliente y el servidor contra la escucha clandestina y el secuestro de sesión (Bambu Mobile, 2024). Por esta razón, el monitoreo de /var/log/auth.log descrito en el punto 1 no es una práctica arbitraria, sino la verificación directa de que ese canal seguro no está siendo vulnerado mediante intentos de fuerza bruta.

2- Detección

Se describen a continuación las fuentes de detección de incidentes contempladas en el sistema, junto con la herramienta o comando asociado a cada una.

Fuente	Qué se monitorea	Herramienta/comando
Logs de acceso SSH	Intentos de login fallidos, IPs no habituales	/var/log/auth.log ; grep "Failed password"
Logs de la aplicación PHP	Excepciones no controladas, errores 500 repetidos	Log de errores configurado en el módulo de "manejo de errores y excepciones"
Logs de MySQL	Consultas anómalas, errores de sintaxis sospechosos (indicio de intento de inyección)	general_log o slow_query_log
Estado de contenedores	Caídas, reinicios inesperados, uso anómalo de CPU/RAM	docker stats ; docker ps -a
Sesiones activas	Un mismo usuario logueado desde IPs distintas simultáneamente	Tabla de sesiones / control de sesión (RBAC)

Criterios de escalamiento — de anomalía a incidente confirmado:

- Cada detección abre un ticket interno en el propio SGRSI (mesa de ayuda), con severidad asignada (Alta/Media/Baja) y responsable designado.
- Se define un umbral de referencia, por ejemplo: "más de 5 intentos fallidos de login en 2 minutos desde la misma IP".
- Todo error de aplicación que exponga datos de la base se trata directamente como incidente, no como bug.

3- Respuesta

Se detallan a continuación las acciones inmediatas de contención, en correspondencia con los requerimientos exigidos por la letra del proyecto.

Situación detectada	Acción de contención	Base en la letra
Intentos de SQLi en formulario	Bloquear IP de origen	Script de Gestión de Firewall
Cuenta comprometida (credenciales filtradas)	Deshabilitar cuenta (cambio de estado en tabla "usuarios") y forzar logout de la sesión activa	Control de sesiones, incluyendo login y logout
Escalada de privilegios (Solicitante actuando como Admin)	Revisar y revertir el rol asignado; revisar la ruta que falló	Protección de rutas y control de acceso según sesión/rol
Contenedor comprometido o caído	docker stop <contenedor> de forma aislada, sin detener toda la plataforma	Gestión y administración de contenedores (docker-compose)
Sospecha de exfiltración de datos	Cortar el acceso a la base de datos desde el contenedor afectado	Gestión de bases de datos

Comunicación interna durante la respuesta:

- El Técnico/Soporte que detecta el incidente notifica al Administrador/Coordinador, conforme a los roles definidos en el sistema.
- Se documentan la hora de detección, la hora de contención y la acción tomada; esta información alimenta el informe post-incidente.

4- Recuperación

Los pasos de recuperación se ejecutan en el siguiente orden:

1. Confirmar que la causa raíz fue erradicada antes de restaurar. Restaurar sin corregir la falla reintroduce el mismo incidente.
2. Ejecutar la restauración desde el servidor de respaldo, conforme a lo exigido por la letra: "backup íntegro del sistema como sistema de contingencia ante pérdidas importantes" (Administración de Sistemas Operativos, 3ª entrega).
3. Verificar la integridad de la base de datos restaurada:
   - Consistencia referencial (claves foráneas intactas).
   - Cumplimiento de la 3FN, sin duplicación de datos.
   - Conteo de registros críticos (usuarios, equipos, tickets) contra el último respaldo conocido.
4. Reactivar el contenedor o servicio mediante docker-compose up -d.
5. Monitorear los logs durante las primeras horas posteriores a la recuperación antes de dar el incidente por cerrado.

5. Prevención

Para cada tipo de incidente se establece la corrección concreta que cierra el ciclo de mejora continua:

Causa raíz	Corrección permanente
Falló la sanitización de un input	Revisar y reforzar la "sanitización de entrada y salida de datos" en el endpoint puntual afectado
No se usó consulta preparada en algún punto	Auditar todas las queries del módulo afectado, no solo la que falló
Contraseña débil o mal encriptada	Revisar la política de complejidad y el método de encriptación utilizado, justificándolo nuevamente
Backup no se ejecutó o falló silenciosamente	Agregar verificación automática post-backup (por ejemplo, chequeo de tamaño de archivo y log de éxito/falla)

Causa raíz	Corrección permanente
El firewall no bloqueó el ataque	Revisar las reglas del script de Gestión de Firewall y agregar la regla faltante
Adjunto o enlace malicioso recibido a través de la mesa de ayuda (ticket)	Capacitar a Solicitantes y Técnicos en identificación de correos/tickets sospechosos y verificación antes de abrir adjuntos, como medida de vigilancia contra phishing

Estas correcciones se alinean con buenas prácticas de ciberseguridad ampliamente reconocidas, gestión de contraseñas y autenticación de dos factores, cifrado de bases de datos, control de acceso basado en roles, vigilancia del correo electrónico, planes de recuperación de datos, mantenimiento de firewall y protocolos de reporte de incidentes (Bambu Mobile, 2024).

Informe post-incidente

Todo incidente cerrado debe documentarse mediante un informe post-incidente que contemple, como mínimo, los siguientes campos:

- Qué pasó.
- Cómo se detectó.
- Tiempo de respuesta.
- Acción tomada.
- Corrección aplicada.
- Fecha.

Referencias bibliográficas

Bambu Mobile: https://bambu-mobile.com/protocolos-de-ciberseguridad/

Benegas,L.(s.f.): https://prezi.com/p/ffkgselyiekn/protocolos-de-seguridad-informatica/